

ACG — Executive Overview & Strategic Brief

“AI proposes. ACG authorizes. Razorpay executes.”

“The model can propose anything. It cannot authorize anything.”

“ACG does not decide what the AI should buy. It decides whether the AI is allowed to cause the financial action.”

1. What ACG Is

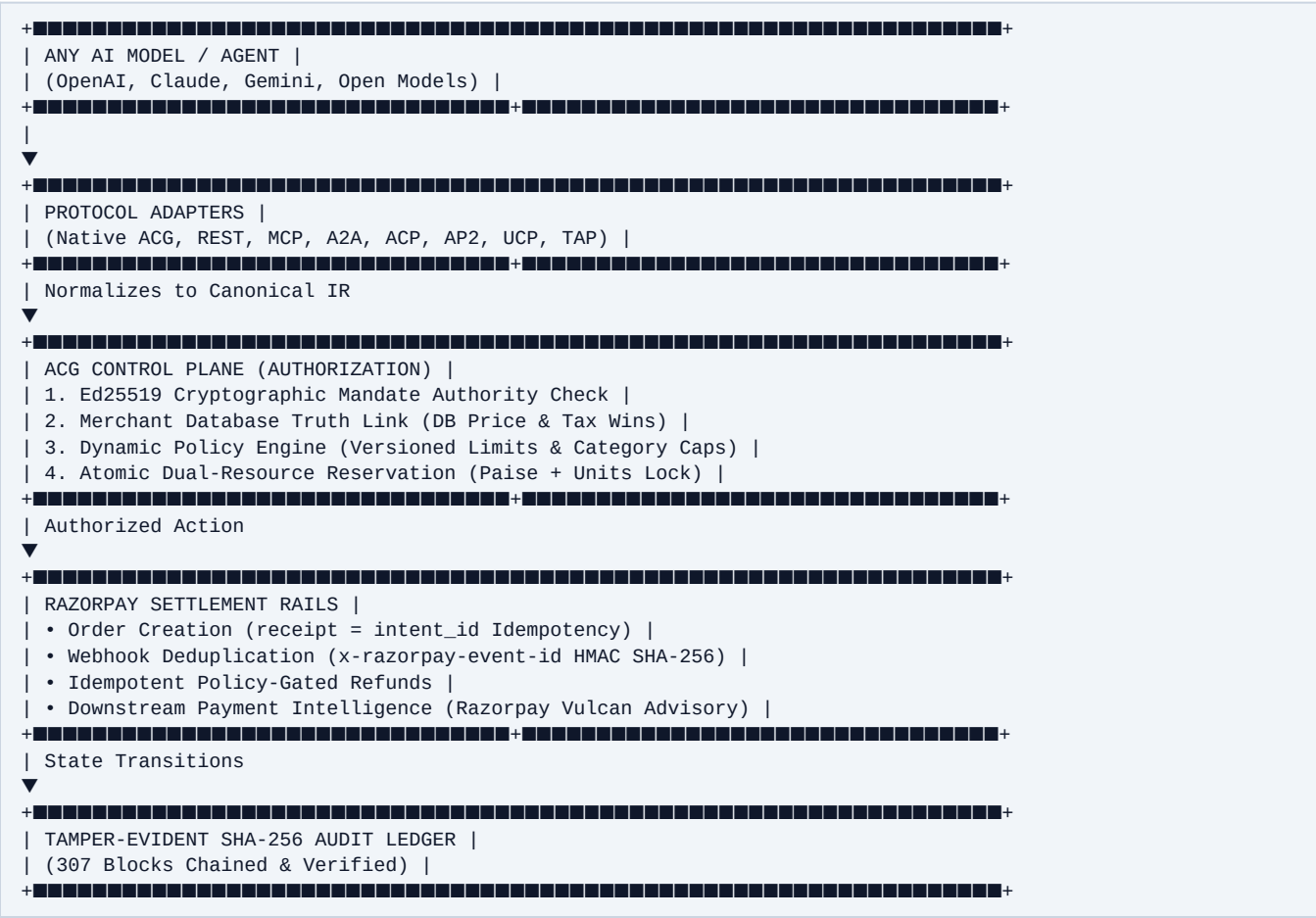
The **Agent Commerce Gateway (ACG / MACCP)** is a merchant-side authorization control plane for AI-originated financial actions. It converts autonomous agent intent into a canonical financial action, verifies delegated human authority, grounds decisions in merchant catalog truth, enforces merchant policy and resource constraints, and only then permits execution through payment settlement infrastructure. ACG is complementary to payment execution infrastructure.

2. The Core Problem

As autonomous AI agents advance from conversational discovery to purchasing goods and services, merchants face fundamental risks:

1. **Prompt Injection & Price Manipulation:** Agents can invent prices or claim unauthorized discounts.
 2. **Subagent Budget Overstep:** Subagents can exceed delegated spending limits.
 3. **High-Concurrency Double-Spending:** Parallel subagents can race against remaining funds or inventory.
 4. **Lack of Cryptographic Provenance:** Merchants require cryptographic proof of buyer delegation and a tamper-evident audit trail.
-

3. High-Level Architecture



4. Five Key Security Controls

- 1. **Cryptographic Mandate Authority:** Buyer spending permissions are signed with Ed25519; canonical byte serialization prevents tampering.
- 2. **Merchant Truth Isolation:** Authoritative pricing and GST calculations are read exclusively from SQLite; all LLM price arithmetic is ignored.
- 3. **Dynamic Policy DSL:** Versioned policies (pol_v1.0.0) enforce transaction caps, category restrictions, and auto-refund policies.
- 4. **Atomic Dual-Resource Locking:** Serialized database transactions atomically lock mandate budget paise and catalog unit stock simultaneously.
- 5. **Tamper-Evident SHA-256 Audit Trail:** Every transition is recorded in a forward hash-chained ledger, verifiable via `npm run audit:verify`.

5. Five Verified Headline Metrics

- * 77 / 77 Automated Tests Passing (across 9 test suites).
- * 19 / 19 Live Adversarial HTTP Scenarios Intercepted (0 breaches).
- * 0 Unauthorized Financial-Impact Paths Observed in tested scenarios.

- * **303.81 ms Measured Cold-Run Latency** (end-to-end Razorpay order creation).
 - * **307 SHA-256 Audit Blocks Verified** across all database instances.
 - * **Razorpay Sandbox Execution PASS** (HMAC-verified webhooks and idempotent orders).
-

6. Current Deployment Status & Production Boundary

- * **Status: PASS WITH OBSERVATIONS** — Ready for Controlled Sandbox / Buildathon Evaluation.
- * **Verified Reference Implementation:** Single-node SQLite ACID persistence model with serialized transaction coordination.
- * **Production Scaling Target:** Production scaling requires migration from the verified single-node SQLite reference implementation to a distributed persistence architecture such as PostgreSQL, with appropriate transactional resource coordination and enterprise-managed key-management infrastructure. The exact distributed locking and key-management technologies are deployment decisions rather than requirements of the ACG authorization model.